

1. Scope and Methodology

Security testing was conducted against a locally hosted instance of OWASP Juice Shop running at localhost:3000 — an intentionally vulnerable application purpose-built for security training, used as a replacement for Instasafe staging since credentials and written authorization were not yet provisioned. An automated scan was also run against the public instance at demo.owasp-juice.shop before it became unavailable. Testing followed OWASP Testing Guide v4.2 methodology. Tools used: OWASP ZAP 2.17.0 for automated scanning, Burp Suite Community v2026.4.3 for manual testing, jwt.io for token analysis, and securityheaders.com for header verification.

2. Findings Table

#	Vulnerability	Severe	CVSS Score	Endpoint	Recommendation
F-01	CSP Header Not Set	Medium	5.3	All pages	Add Content-Security-Policy header restricting approved sources
F-02	HSTS Header Not Set	Medium	4.3	All pages	Add Strict-Transport-Security: max-age=31536000; includeSubDomains
F-03	Password Hash Exposed in JWT	Critical	9.1	/rest/user/login	Remove password field from JWT payload entirely
F-04	Server Version Disclosed	Low	3.7	All responses	Remove Server header or return generic value
F-05	IDOR on User/Basket Resources	Medium	6.5	/rest/basket/6	Validate resource ownership server-side before returning data
F-06	Referrer-Policy Header Missing	Low	3.1	All pages	Add Referrer-Policy: strict-origin-when-cross-origin

3. Risk Summary

Total findings: 6. Critical: 1 (password hash in JWT — immediate fix required). Medium: 3 (CSP, HSTS, IDOR). Low: 2 (server version disclosure, missing Referrer-Policy). Priority order: Fix F-03 immediately, then F-05, then implement missing security headers F-01 and F-02 together, then F-04 and F-06